

DOCUMENT 3.2 — SECURITY & ACL CONFIGURATIONS

Folder 3: Data Model & Security Construction Phase | ServiceNow Capstone Project Submission

Project Title: Hospital Appointment Management System

Platform: ServiceNow (Scoped Application)

Application Scope: x_2065601_hospit_0

Author / Student: Santhosh Akkisetti

1. Security Model & Role Architecture

Security within the **Hospital Appointment Management System** is governed through Role-Based Access Control (RBAC) enforced at the ServiceNow Access Control List (ACL) layer. Custom roles defined in application scope `x_2065601_hospit_0` restrict table access, field-level edits, and record creation based on strict principles of least privilege.

Role Name	Role Key / Name Value	Access Level & Description
Admin	x_2065601_hospit_0.admin	Full system administration, complete CRUD operations across all 5 tables, system configuration, and user assignment.
Doctor	x_2065601_hospit_0.doctor	Read access to assigned patient records, create/update access for own doctor slots, update access for assigned appointments (check-in/complete).
Patient	x_2065601_hospit_0.patient	Read access to published doctor slots, create/read/cancel access for self-owned appointment and waitlist records.

2. Access Control List (ACL) Matrix

The following matrix details table-level and row-level security Access Control Lists (ACLs) configured to protect health record integrity and patient data privacy across all five custom tables:

Target Table	Operation	Required Role(s)	Condition / Script Constraint
x_2065601_hospit_0_patient	read	admin, doctor, patient	Patients can only view their own profile record (email == gs.getUser().getEmail()).
	create	admin, patient	Self-registration via Service Portal or admin profile creation.
	write / delete	admin	Restricted strictly to system administrators.
x_2065601_hospit_0_doctor	read	admin, doctor, patient	Publicly readable for directory search and appointment scheduling.
	create / delete	admin	Restricted to admin for physician onboarding and offboarding.
	write	admin, doctor	Doctors can update personal department and availability status.

Target Table	Operation	Required Role(s)	Condition / Script Constraint
x_2065601_hospit_0_doctor_slot	read	admin, doctor, patient	All users can view available slots.
	create / write	admin, doctor	Doctors can generate and modify their own schedule slots.
	delete	admin	Restricted strictly to system administrators.
x_2065601_hospit_0_appointment	read	admin, doctor, patient	Patients read self-owned records; Doctors read assigned patient records.
	create	admin, patient	Booking enabled for registered patients and admins.
	write	admin, doctor, patient	Patients can cancel; Doctors can update appointment status (Checked-In/ Completed).
x_2065601_hospit_0_waitlist	read / create	admin, patient	Patients view and join waitlists for filled slots.
	write / delete	admin	Automated status updates managed by system Business Rules.

Cross-Scope Privilege Security:

Restricted Caller Access (RCA) records are explicitly configured to allow the x_2065601_hospit_0 application scope to safely execute scripts against platform tables (such as sys_user) without compromising platform security.